Cisco Secure Workload - GxP Compliance Report

Cisco Secure Workload - GxP Compliance Report

Customer-Facing Compliance Report

Framework: GxP computerised-system controls: EU GMP Annex 11, 21 CFR Part 11, GAMP 5 (2nd Edition)
Primary audience: Life-sciences organisations operating GxP-regulated computerised systems: pharmaceutical and biotech manufacturers, medical-device manufacturers, CDMOs and CROs, and their quality / validation / IT-compliance functions.
CSW positioning: Demonstrable segregation of the validated estate from the non-validated estate, change control and drift detection on validated systems, and compensating controls for validated systems that cannot be patched without revalidation.

Framework Version Note

References EU GMP Annex 11 (current published version) and 21 CFR Part 11, read alongside GAMP 5 Second Edition (2022) and the FDA Computer Software Assurance draft guidance (September 2022). GxP is a regulatory regime enforced by inspection, not a certification scheme - there is no GxP certificate to obtain. The EU is revising Annex 11; validate against the version in force for the customer's market before using these references in a regulatory submission.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (`CSW-GxP-Reference-Design.md`) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

> The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW "certifies" compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer's compliance team, and the customer's assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer's governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

```
GxP
├── GxP-Validated (MES, LIMS, EBR, SCADA-Historian, Chromatography-Data-Systems)
├── GxP-Supporting (Backup, Monitoring, Time-Sync, Infrastructure-Services)
├── Non-GxP-Corporate (Office-IT, Email, General-Business-Applications)
└── External-Partners (CDMO, CRO, Instrument-Vendor-Remote-Support)
```

This scope pattern should be validated with the customer's architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Annex 11 §12.1 - physical and logical segregation of validated systems
- Annex 11 §10 / §12.2 - change control and unauthorised-change detection
- Annex 11 §11 - periodic evaluation evidence for the network control layer
- Annex 11 §9 - audit trail of the segmentation control itself
- Annex 11 §13 - incident scoping and workload-level timeline reconstruction
- Annex 11 §7.1 / §16 - data-store and continuity dependency visibility
- 21 CFR Part 11 §11.10(d) - limiting system access to authorised individuals (network layer)
- Compensating controls for validated systems that cannot be patched
- Validated System Inventory (VSI) reconciliation inputs
- GMP manufacturing OT boundary hardening on the IT side of the Purdue model

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Computer System Validation (CSV) - IQ/OQ/PQ of the regulated application
- Record-level ALCOA+ attributes (attributable, legible, contemporaneous, original, accurate)
- Electronic signature capability (21 CFR Part 11 Subpart C)
- Application-level audit trails and audit-trail review (Part 11 §11.10(e) at record level)
- Quality Management System, SOPs, deviation and CAPA processes
- Supplier qualification and vendor assessment
- Data integrity governance and periodic data-integrity review
- Qualification of CSW itself, which may be required where CSW is relied upon as a GxP control

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Annex 11 §12.1 - access/segregation of validated systems	**Direct**	Scope tree keyed on validation status; enforced allowlist between GxP-Validated and all other scopes	Policy workspace export showing the Non-GxP-Corporate to GxP-Validated boundary with enforcement state
Annex 11 §12.2 - unauthorised change detection	**Direct**	Policy drift / ‘out of sync’ detection on enforced workloads	Drift report listing workloads whose host firewall no longer matches the approved policy
Annex 11 §10 - change control	**Direct**	Simulate-before-enforce impact analysis on the validated estate	Simulation output attached to the change record as pre-implementation impact evidence
Annex 11 §11 - periodic evaluation	**Direct**	Scheduled inventory, policy and flow extracts for the validated estate	Periodic evaluation pack covering scope membership, policy state and observed flows
Annex 11 §9 - audit trail of the control	**Direct**	CSW change log for scopes, policies and enforcement state	Control-plane audit trail; note this is the audit trail of the control, not of the GxP record
Annex 11 §13 -	**Direct**	Forensic flow and	Investigation pack

Framework topic	Coverage	CSW capability	Evidence artifact
incident management		process search scoped to the validated estate	with affected validated workloads and time window
Annex 11 §16 - business continuity	**Supporting**	Dependency mapping for validated systems and their supporting services	Observed-dependency map used as input to continuity impact analysis
21 CFR Part 11 §11.10(d) - authorised access	**Direct**	Workload-to-workload allowlist restricting reachability of Part 11 systems	Enforced policy set for systems holding Part 11 electronic records
Un-patchable validated systems	**Direct**	Reachability-weighted CVE plus compensating segmentation policy	Compensating-control register linking each deferred CVE to the policy that contains it
Validated System Inventory reconciliation	**Supporting**	Workload inventory with validation-status labels	Inventory export reconciled against the quality-owned VSI

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Validated-estate inventory	Workload inventory with validation-status labels and scope membership	Workload inventory + scope membership export	Monthly, and before each periodic evaluation
Validated/non-validated boundary	Enforced policy set at the GxP-Validated boundary	Policy workspace export with enforcement state	Quarterly + after each change
Change-control impact evidence	Pre-implementation simulation for each policy change on validated systems	Policy simulation output	Per change request
Drift / unauthorised change	Workloads out of sync with approved policy	Policy drift report	Weekly
Periodic evaluation	Inventory, policy,	Combined scope,	Per the periodic-

Topic	What to collect	CSW source	Suggested cadence
pack	drift and flow extracts for the validated estate	workspace and flow exports	evaluation schedule, typically annually
Compensating controls for deferred patches	Deferred CVE paired with the containing policy	Vulnerability report scoped to GxP-Validated + matching policy export	Monthly
Time-synchronisation path	Reachability of the authoritative NTP source from validated workloads	Flow search confirming NTP reachability	Quarterly
Incident sample	Workload-level timeline for one representative incident on a validated system	Flow + process search	Per incident; one representative sample per evaluation cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. `tenant`, `prototype`, `isa_level`, `npi`, `cui`, `ephi`).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not perform Computer System Validation, does not produce record-level ALCOA+ evidence, provides no electronic-signature capability, and does not supply application-level audit trails. The CSW audit trail covers the segmentation control, not the GxP record. Where CSW is relied upon as a GxP control, the customer's quality function may require CSW itself to be qualified. GxP is enforced by inspection and nothing here confers compliance.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer’s qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer’s environment, and qualified compliance, legal, and audit professionals.